1. INTRODUCCIÓ A LA SEGURETAT INFORMÀTICA

1. Definició

Segons el diccionari de la llengua catalana:

- Seguretat → Qualitat de segur.
- Segur → Exempt de tot perill o risc.

Aleshores la 'seguretat informàtica' és la qualitat d'un sistema informàtic d'estar exempt de tot perill?

Doncs no: *consisteix en assegurar que els recursos d'una organització siguin utilitzats de la manera que es va decidir i que l'accés a la informació només sigui possible a les persones acreditades.*

La seguretat és un procés no un producte acabat.

La seguretat informàtica no es pot mesurar

Podem desenvolupar eines per quantificar d'alguna manera la nostra inseguretat informàtica.

Aleshores la solució a la Seguretat informàtica és estar desconnectat de la xarxa o apagats?
Doncs trobem que igualment que estigui apagat segueix sense ser 100% segur.

Frase cèlebre d'Eugene H. Spafford: *"L'únic sistema que és totalment segur és aquell que es troba apagat i desconnectat, guardat en una caixa forta de titani que està soterrada amb ciment, rodejada de gas nerviós i d'un grup de guardes fortament armats. Encara així, no apostaria la meva vida en això."*

2. Debilitats d'un sistema informàtic

Les debilitats d'un sistema informàtica poden ser externes o internes i s'han d'aplicar polítiques, metodologies i tècniques de protecció de la informació perquè la connectivitat és VITAL. Per això el compliment dels estàndards de gestió de la seguretat és sinònim de Qualitat de Servei.

Referent a la delinqüència informàtica, trobem que per diferents països et pots trobar que un mateix acte sigui o no delicte. I tot i que pot semblar atractiu i un bon negoci, la informació robada en contenidors petit (USB, CD, etc) pot no ser la més valuosa, ja que aquesta son les dades que contenen.

Per aquest motiu, trobem que la criptografia és l'eina més efectiva per la protecció de la seguretat informàtica.

3. Introducció a la Criptografia

La criptografia és la branca de les matemàtiques que fa ús de mètodes i tècniques amb la finalitat de xifrar, i llavors de protegir, un missatge (o arxiu) mitjançant un algoritme usant una o més claus.

Tot i que per influència anglesa s'utilitza la paraula *encriptar*, aquesta realment té més a veure en l'acte 'd'introduir a algú dins d'una cripta'. Una cosa diferent al que volem expressar.

Xifrar és la tècnica que protegeix o autentica a un document o usuari en aplicar un algoritme criptogràfic. Sense conèixer una clau específica o secreta, no serà possible desxifrar-ho o recuperar-ho. Tot i això, al diccionari ho defineix com a «*Transcriure en guarismes, lletres o símbols, d'acord amb una clau, un missatge el contingut del qual es vol ocultar»*

4. Principis de la seguretat informàtica

Quan nosaltres ens plantegem la seguretat, aquesta ha d'abastar dos àmbits:

1. SEGURETAT FÍSICA

És la protecció del sistema davant amenaces físiques: incendis, inundacions, control d'accessos a persones, instal·lacions (electricitat...)

2. SEGURETAT LÒGICA

- És la protecció de la informació en el seu propi medi. Normalment es realitza mitjançant tècniques criptogràfiques.

- *Exemple*: accés al despatxos
  - És un exemple dels costums que ens podem torbar en grans empreses.
  - És fàcil el robatori d'equips, ja que és habitual veure persones amb equips informàtics als passadissos (tècnics, trasllats..).
  - Es pot accedir al sistema sense necessitat de robar-lo. Amb un DVD i reiniciant l'ordinador podem accedir a informació confidencial.
  - SOLUCIÓ: control d'accessos (físic i lògic)

- *Exemple*: instal·lacions
  - CONDICIONAMENT: cada vegada s'acumulen més servidors a les sales. Pot suportar el terra tant de pes? Està ubicat a un zona inferior, amb tubs de desguàs? Comparteix armaris amb altres serveis, com el telèfon?
  - ELECTRICITAT: Cada vegada més servidors. Que passa amb la línia elèctrica? Pot ocórrer una caiguda de la intensitat del corrent. Necessitem comprar SAI's, generadors i potser una solució seria la combinació dels dos anteriors.
  - REFRIGERACIÓ: sense aparell d'aire condicionat tindrem temperatures MOLT elevades que provocaran problemes en els servidor. Es necessita SAI?
  - INCENDIS: s'ha de preveure totes les possibles generacions de fos que pot ocórrer, com per exemple prohibir fumar. Hem de disposar d'uns sistema de contenció del foc. Hi ha empreses especialitzades en aportar solucions adients a cada cas.

La gestió de la seguretat per a poder abastir-ho tot és amb '*plans de contingència*', '*polítiques de seguretat*', '*normatives*'...

5. Principis de la seguretat informàtica

Tres principis bàsics:

1. Quins son els punts dèbils d'uns sistema informàtic?

L'intrús al sistema utilitzarà les eines que faci més fàcil el seu accés i posterior atac.
Existirà una diversitat de fronts des dels quals pots produir-se un atac, tant interns com externs. Això dificultarà l'anàlisi de risc ja que el delinqüent aplicarà la filosofia de l'atac cap al punt més feble: l'equip o les persones.

2. Quant de temps s'ha de protegir una dada?

- Les dades confidencials han de protegir-se només fins que aquest secret perdi el seu valor coma tal.
- Es parla, per tant, de la caducitat del sistema de protecció: temps en el qual ha de mantenir-se la confidencialitat o secret de la dada.
- Això ens portarà a la fortalesa del sistema de xifrat.

3. Quina és la eficiència de les mesures presses?

- Les mesures de control s0implementen perquè tinguin un comportament efectiu, eficient, siguin fàcils d'usar i apropiades al mitjà.
    - Efectiu: que funcionin en el moment oportú.
    - Eficient: que optimitzin els recursos del sistema.
    - Apropiades: que passin desapercebudes per a l'usuari.
    - Cap sistema de control resulta efectiu fins que hem d'utilitzar-ho en sorgir la necessitat d'aplicar-ho.
- Juntament amb la conscienciació dels usuaris, aquest serà un dels grans problemes de la Gestió de la Seguretat Informàtica.

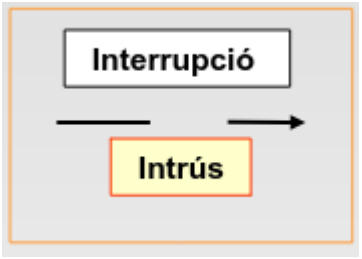
6. Amenaces del sistema informàtic

Les amenaces afecten als elements vulnerables: Hardware, software, dades.

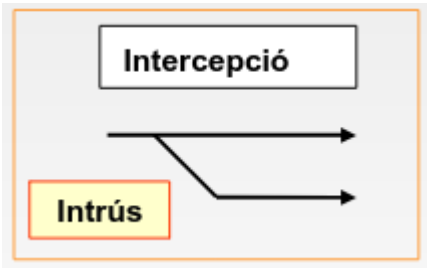
Es deuen als fenòmens de: flux normal, interrupció, intercepció, modificació i generació.

1. **Flux normal**: no hi ha amenaces al sistema informàtica.

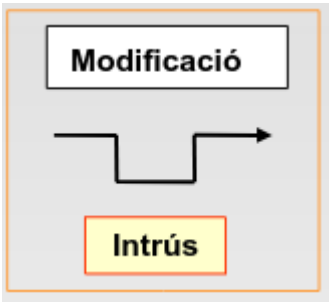
2. **Amenaça interrupció**: es malmet o deixa de funcionar el sistema. La seva detecció és immediata. Un exemple és quan s'esborra de cop un programa.



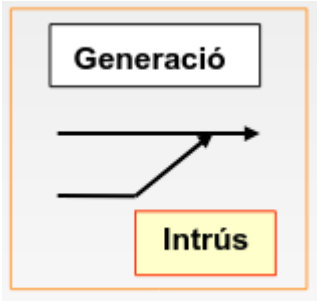
3. **Amança d'intercepció**: accés a la informació per part de persones sense autorització. Ús de privilegis no adquirits. La detecció és difícil ja que no deixa empremtes. Per exemple quan es copien dades.



4. **Amenaça de modificació**: accés no autoritzat que canvia l'entorn per al seu benefici. La seva detecció és difícil. Per exemple la modificació d'una BD.



5. **Amenaça de generació**: creació de nous objectes dintre del sistema. La seva detecció és difícil: delictes de falsificació. Per exemple afegir noves transaccions.



El que ens trobarem en els diferents escenaris és que les diferents amenaces faran sempre que les dades siguin la part més vulnerable del sistema.

7. Debilitats d'un sistema informàtic (2)

L'anomenat triangle de la debilitat del sistema està conformat pel maquinari, el programari i les dades:

- Maquinari: poden produir-se errors intermitents, connexions soltes, desconnexió de targetes etc.
- Programari: pot produir-se la subtracció de programes, execució errònia, modificació, defectes en trucades al sistema, etc.
- Dades: pot produir-se l'alteració de continguts, introducció de dades falses, manipulació fraudulenta de dades etc.

D'altre banda també es considere debilitats del sistema:

- Memòria: por produir-se la introducció d'un virus, dolent ús de la gestió de memòria, bloqueig del sistema, etc.
- Usuaris: pot produir-se la suplantació d'identitat, l'accés no autoritzat, visualització de dades confidencials, etc.

Tot i que és difícil dissenyar un pla que contempli minimitzar de forma eficient totes aquestes amenaces, i que a més s'entengui i passi desapercebut pels usuaris.

8. CIDAN

Podem parlar d'un sistema informàtic fiable quan se satisfan les tres propietats següents



1. Confidencialitat: només poden accedir als recursos que integren el sistema els elements autoritzats a fer-ho. Per recursos del sistema no només s'entén la informació, sinó qualsevol recurs en general: impressores, processador etc.

2. Integritat: els recursos del sistema només poder ser modificats o alterats pels elements autoritzats a fer-ho. La modificació inclou diverses operacions, com ara l'esborrament i la creació, a més de totes les possibles alteracions que es puguin fer sobre un objecte

3. Disponibilitat: els recursos del sistema han de romandre accessibles als elements autoritzats.

Juntament a aquest conceptes es sol estudiar:

4. Autenticació: verificar que un document ha estat elaborat per la persona qui diu que ho ha fet. Verificar que una persona és qui diu que és.
5. No rebuig: Molt relacionat amb l'autenticació. Dos possibilitats: en origen (emissor que nega l'enviament) i el destí (receptor que nega la rebuda).